# Executive Summary

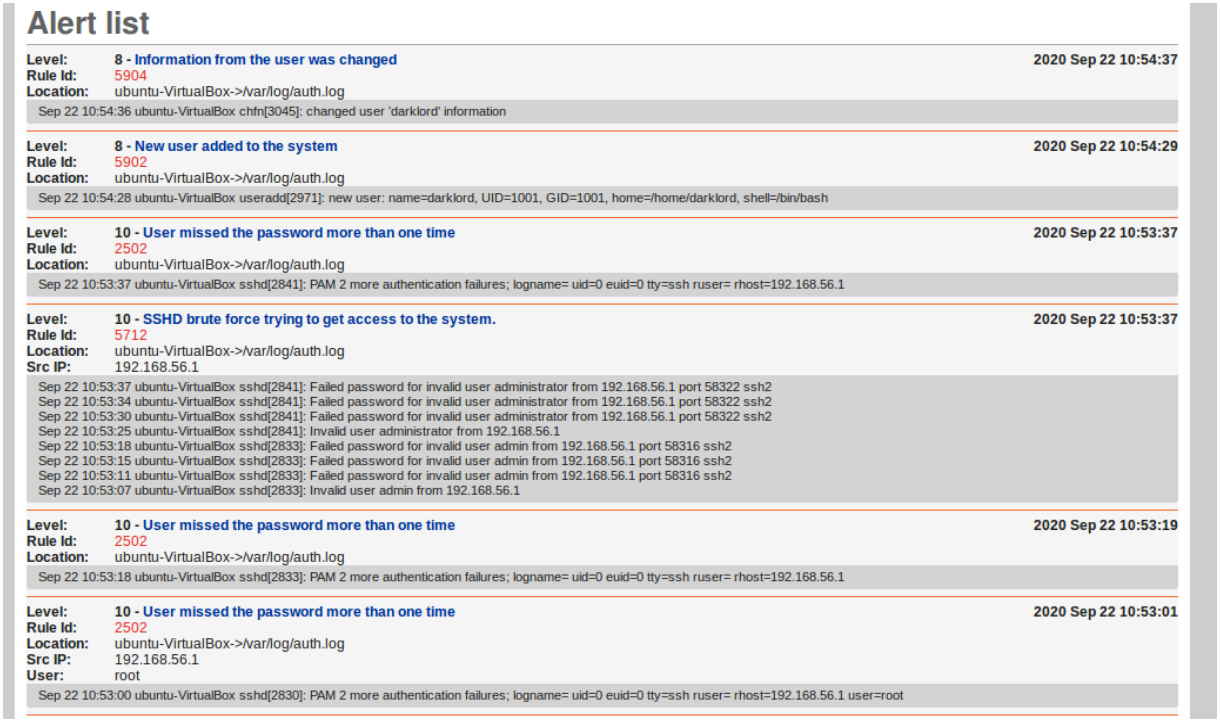
***(Confidential Document)***

Dear Executives,

During the national holiday, we observed a cyberattack on our servers. Below are the findings of our investigation and our mitigation steps:

## Key Findings:

- The National Peace Agency of North Udan executed this cyberattack.
- The attack started when a malicious IP **(192.168.56.1)** managed to bruteforce our jump-host server and gain remote access.
- The attacker then created a new username **(darklord)** for himself, escalated his privileges to root (administrator) and planted a backdoor under a process called **(remotesec)** with port number **(56565)**
- Using the backdoor, the attacker planted three known variants of malware, and one entirely new called **(SSH-One).**



Alert list

Level: 8 - Information from the user was changed — 2020 Sep 22 10:54:37
Rule Id: 5904
Location: ubuntu-VirtualBox->/var/log/auth.log
Sep 22 10:54:36 ubuntu-VirtualBox chfn[3045]: changed user 'darklord' information

Level: 8 - New user added to the system — 2020 Sep 22 10:54:29
Rule Id: 5902
Location: ubuntu-VirtualBox->/var/log/auth.log
Sep 22 10:54:28 ubuntu-VirtualBox useradd[2971]: new user: name=darklord, UID=1001, GID=1001, home=/home/darklord, shell=/bin/bash

Level: 10 - User missed the password more than one time — 2020 Sep 22 10:53:37
Rule Id: 2502
Location: ubuntu-VirtualBox->/var/log/auth.log
Sep 22 10:53:37 ubuntu-VirtualBox sshd[2841]: PAM 2 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.56.1

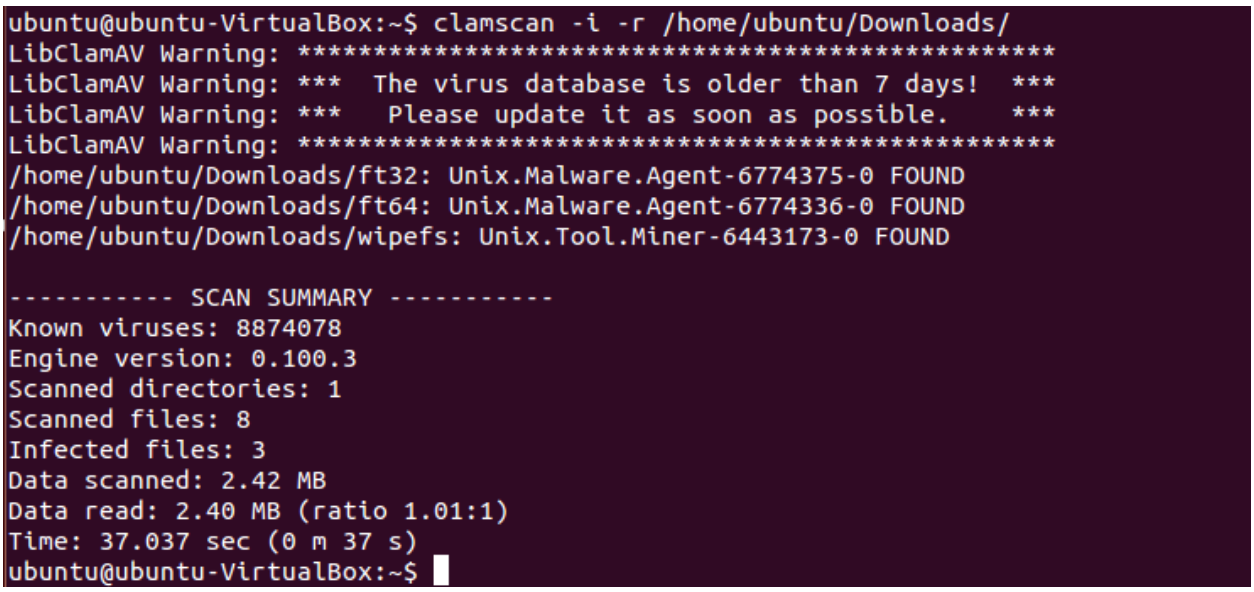
Level: 10 - SSHD brute force trying to get access to the system. — 2020 Sep 22 10:53:37
Rule Id: 5712
Location: ubuntu-VirtualBox->/var/log/auth.log
Src IP: 192.168.56.1
Sep 22 10:53:37 ubuntu-VirtualBox sshd[2841]: Failed password for invalid user administrator from 192.168.56.1 port 58322 ssh2
Sep 22 10:53:34 ubuntu-VirtualBox sshd[2841]: Failed password for invalid user administrator from 192.168.56.1 port 58322 ssh2
Sep 22 10:53:30 ubuntu-VirtualBox sshd[2841]: Failed password for invalid user administrator from 192.168.56.1 port 58322 ssh2
Sep 22 10:53:25 ubuntu-VirtualBox sshd[2841]: Invalid user administrator from 192.168.56.1
Sep 22 10:53:18 ubuntu-VirtualBox sshd[2833]: Failed password for invalid user admin from 192.168.56.1 port 58316 ssh2
Sep 22 10:53:15 ubuntu-VirtualBox sshd[2833]: Failed password for invalid user admin from 192.168.56.1 port 58316 ssh2
Sep 22 10:53:11 ubuntu-VirtualBox sshd[2833]: Failed password for invalid user admin from 192.168.56.1 port 58316 ssh2
Sep 22 10:53:07 ubuntu-VirtualBox sshd[2833]: Invalid user admin from 192.168.56.1

Level: 10 - User missed the password more than one time — 2020 Sep 22 10:53:19
Rule Id: 2502
Location: ubuntu-VirtualBox->/var/log/auth.log
Sep 22 10:53:18 ubuntu-VirtualBox sshd[2833]: PAM 2 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.56.1

Level: 10 - User missed the password more than one time — 2020 Sep 22 10:53:01
Rule Id: 2502
Location: ubuntu-VirtualBox->/var/log/auth.log
Src IP: 192.168.56.1
User: root
Sep 22 10:53:00 ubuntu-VirtualBox sshd[2830]: PAM 2 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.56.1 user=root

## Mitigation Steps:

- After identifying the malware using ClamAV and manual inspection, we deleted the malware and created a new YARA rule to detect **(SSH-One).**
- We then blocked the malicious IP responsible for the attack using Iptables and we blocked root (administrator) SSH access.




** Known Malware*

## System Hardening:

After this cyberattack, we had to harden our servers to make sure this does not happen again.

- OpenVAS scan for vulnerabilities and manual patching for them.
- Hiding version information for Apache which helps make reconnaissance harder.
- Deprivileging Apache to make it harder for attackers even if they get remote code execution to our web server.

| Vulnerability | Severity | QoD | Host | | Location | EPSS | | Created |
|---|---|---|---|---|---|---|---|---|
| | | | IP | Name | | Score | Percentage | |
| Operating System (OS) End of Life (EOL) Detection | 10.0 (High) | 80 % | 192.168.1.5 | | general/tcp | N/A | N/A | Fri, May 2, 2025 4:00 PM |
| Weak Key Exchange (KEX) Algorithm(s) Supported (SSH) | 5.3 (Medium) | 80 % | 192.168.1.5 | | 22/tcp | N/A | N/A | Fri, May 2, 2025 4:00 PM |
| Weak Host Key Algorithm(s) (SSH) | 5.3 (Medium) | 80 % | 192.168.1.5 | | 22/tcp | N/A | N/A | Fri, May 2, 2025 4:00 PM |
| Weak Encryption Algorithm(s) Supported (SSH) | 4.3 (Medium) | 80 % | 192.168.1.5 | | 22/tcp | N/A | N/A | Fri, May 2, 2025 4:00 PM |
| TCP Timestamps Information Disclosure | 2.6 (Low) | 80 % | 192.168.1.5 | | general/tcp | N/A | N/A | Fri, May 2, 2025 4:00 PM |
| Weak MAC Algorithm(s) Supported (SSH) | 2.6 (Low) | 80 % | 192.168.1.5 | | 22/tcp | N/A | N/A | Fri, May 2, 2025 4:00 PM |
| ICMP Timestamp Reply Information Disclosure | 2.1 (Low) | 80 % | 192.168.1.5 | | general/icmp | N/A | N/A | Fri, May 2, 2025 4:00 PM |

** OpenVAS results*

## Conclusion:

The cyberattack was dealt with in a timely manner, the attacker was permanently blocked and our team made sure to secure our systems even further to prevent this from happening again in the future, alongside recommendations from my side for future work.